Contents

1 Data Protection Impact Assessment (DPIA) 2

1.1 Vitora HMIS — Comprehensive Processing, Risk and Mitigation Report . . . 2
1.2 Contents . . . 3
1.3 1. Executive summary . . . 3
1.3.1 Principal findings . . . 3
1.4 2. Scope, context and DPIA screening . . . 4
1.4.1 2.1 Assessment boundaries . . . 4
1.4.2 2.2 Current particulars and future deployment annex . . . 4
1.4.3 2.3 High-risk screening . . . 4
1.5 3. Accountability and responsibilities . . . 5
1.5.1 3.1 Roles in processing . . . 5
1.5.2 3.2 Operational accountability . . . 5
1.6 4. Data subjects and information categories . . . 5
1.6.1 4.1 People affected . . . 5
1.6.2 4.2 Data classification . . . 6
1.7 5. Processing activity register . . . 6
1.8 6. Data lifecycle, architecture and trust boundaries . . . 7
1.8.1 6.1 Main data flows . . . 7
1.8.2 6.2 Trust boundaries and required checks . . . 7
1.8.3 6.3 Lifecycle requirements . . . 7
1.9 7. Legal basis and regulatory assessment . . . 8
1.9.1 7.1 Applicable framework . . . 8
1.9.2 7.2 Purpose-specific basis profiles . . . 8
1.9.3 7.3 Compliance and evidence matrix . . . 8
1.10 8. Necessity and proportionality . . . 9
1.11 9. Transparency, consent and vulnerable people . . . 9
1.11.1 9.1 Notice and choice . . . 9
1.11.2 9.2 Consent evidence . . . 10
1.11.3 9.3 Children, incapacity and safeguarding . . . 10
1.12 10. Recipients, processors and international transfers . . . 10
1.12.1 10.1 Initial recipient and transfer inventory . . . 10
1.12.2 10.2 Contract requirements . . . 10
1.12.3 10.3 Transfer assessment and localization . . . 11
1.13 11. Retention, deletion and decommissioning . . . 11
1.13.1 11.1 Retention schedule for controller adoption . . . 11
1.13.2 11.2 Deletion, restriction and legal holds . . . 11
1.13.3 11.3 Exit and decommissioning . . . 12
1.14 12. Control assessment and assurance . . . 12
1.14.1 12.1 Evidence labels . . . 12
1.14.2 12.2 Technical and organizational control matrix . . . 12
1.14.3 12.3 Code findings, completed treatment and remaining limits . . . 13
1.15 13. Risk assessment methodology . . . 13
1.15.1 13.1 Scoring . . . 13
1.16 14. Detailed risk register . . . 14
1.17 15. Risk treatment and implementation plan . . . 14
1.17.1 Engineering treatment status — 2 October 2026 . . . 15
1.17.2 Minimum acceptance exercises . . . 15
1.18 16. Data subject rights procedures . . . 15
1.18.1 16.1 Access channels and handling workflow . . . 15
1.18.2 16.2 Rights and deadlines . . . 16
1.19 17. Incident response and continuity . . . 16
1.19.1 17.1 Preparedness and detection . . . 16
1.19.2 17.2 Response steps . . . 16
1.19.3 17.3 Notification obligations . . . 17
1.19.4 17.4 Continuity and clinical safety . . . 17

1.20 18. Consultation, monitoring and review . . . 17
1.20.1 18.1 Consultation register . . . 17
1.20.2 18.2 Monitoring schedule . . . 17
1.20.3 18.3 Reassessment triggers . . . 18
1.21 19. Decision, approval and residual-risk acceptance . . . 18
1.21.1 19.1 Current assessment decision . . . 18
1.21.2 19.2 Product DPIA Execution Record . . . 18
1.21.3 19.3 Residual-risk acceptance record . . . 19
1.21.4 19.4 Annex A: Mandatory Facility Deployment Decision . . . 19
1.22 20. Evidence, legal references and version history . . . 20
1.22.1 20.1 Project evidence register . . . 20
1.22.2 20.2 Legal and regulatory sources . . . 21
1.22.3 20.3 Version history . . . 21

1 Data Protection Impact Assessment (DPIA)

1.1 Vitora HMIS — Comprehensive Processing, Risk and Mitigation Report

Document control	Details
Document ID	VITORA-DPIA-001
Version / assessment date	3.0 / 15 October 2026
Status	**FINAL PRODUCT DPIA — pre-customer product assessment; not authorization for**
Product / developer	Vitora HMIS / Nexora Consulting Ltd.
Assessment entity	Nexora Consulting Ltd. — pre-customer product assessment; healthcare-controller arrangements ar
Covered facilities	Not applicable: Vitora has no customers at this assessment date
Assessment owner / DPO	**Thande W Murito**, Nexora DPO; include the controlled corporate privacy contact in every facili
Technical contributors	Nexora engineering, security, operations and integration owners
Classification	Internal confidential — controlled distribution to controller, authorized reviewers and regulator
Evidence baseline	Source code and regression tests in the working tree based on revision `4b97edda3`; supporting techn
Primary jurisdiction	Kenya; assess additional obligations for each overseas processing location
Scheduled review	By 15 October 2027, or earlier on the triggers in Section 18
Approval record	Section 19; complete the product approval record before relying on this assessment and complete A

How to use this report. This is the final product-wide assessment of the processing activities identified in the evidence baseline, with conditional coverage for optional modules and integrations. It is not a substitute for a healthcare controller's deployment decision. Before live patient-data processing, each controller must complete Annex A, confirm which activities occur, attach operational evidence, close applicable deployment actions, and approve its own risk treatment. A feature described in documentation is not proof that it is enabled, securely configured, or effective in production. An activity may be marked not applicable only with a recorded reason and evidence that its data flow is disabled.

Pre-customer applicability. Nexora confirms that Vitora has **no customers**. This DPIA assesses the product's implemented capabilities and envisaged healthcare processing before customer deployment. Customer facility identities, patient volumes, customer contracts and customer operational evidence are therefore **not applicable yet**, rather than missing facts about a live customer service. They become required in the deployment annex before onboarding and processing. Nexora's own staff/accounts, development, certification and test environments still require appropriate safeguards; absence of customers is not proof that every non-production record is synthetic or anonymous.

Meaning of open fields. Any `Pending`, `proposed`, `to be supplied`, or blank field in this product DPIA does not assert that a control is operating or that a fact is known. It is either a product-governance action requiring the evidence identified in Section 15, or a facility-specific fact that must be completed in Annex A before live patient-data processing. These fields must never be treated as completed by copying this document into a facility file.

1.2 Contents

1. Executive summary
2. Scope, context and DPIA screening
3. Accountability and responsibilities
4. Data subjects and information categories
5. Processing activity register
6. Data lifecycle, architecture and trust boundaries
7. Legal basis and regulatory assessment
8. Necessity and proportionality
9. Transparency, consent and vulnerable people
10. Recipients, processors and international transfers
11. Retention, deletion and decommissioning
12. Control assessment and assurance
13. Risk assessment methodology
14. Detailed risk register
15. Risk treatment and implementation plan
16. Data subject rights procedures
17. Incident response and continuity
18. Consultation, monitoring and review
19. Decision, approval and residual-risk acceptance
20. Evidence, legal references and version history

1.3 1. Executive summary

Vitora HMIS supports the delivery and administration of healthcare through registration, clinical documentation, diagnostics, prescriptions, inpatient and specialist care, insurance claims, payments, public health reporting and related operational services. Its web, desktop, mobile and facility-hub deployment modes can create multiple copies of identifiable health information, including local offline databases, cloud replicas, attachments, messages, audit records and backups.

The anticipated benefits are continuity of care during connectivity interruptions, more accurate clinical records, coordinated treatment, timely reporting, improved financial administration and traceable access to health information. The principal potential harms are disclosure of stigmatizing conditions, discrimination, identity or financial fraud, loss of autonomy, exposure of children or survivors of violence, and clinical injury from inaccurate or unavailable information.

DPIA screening outcome: a DPIA is required. The combined processing involves sensitive health information, vulnerable people, longitudinal record linkage, potential large-scale deployment, international transfers, offline replication, and AI-assisted inference. The assessment addresses the four elements of section 31(2) of the Kenya Data Protection Act: processing description, necessity/proportionality, risks to individuals, and safeguards.

1.3.1 Principal findings

Finding
Patient and emergency-contact encryption properties are present in source; clinical narratives, names and other contextual infor
Tenant scoping, sensitive-record permissions, MFA, emergency access and tamper-evident audit mechanisms are documented
Updated PowerSync streams enforce signed model-read permissions, patient sensitivity and tenant scope, including clinical desc
Replication queries no longer select removed plaintext contact columns or the nonexistent antibiotic-sensitivity `updated_at` colu
Documentation places Neon and PowerSync in EU Central
General Regulations regulation 26 includes primary and secondary healthcare in Kenya
AI, biometric/OTP integrations, diagnostic files, payer exchanges and operational notifications expand the data flow
No customers exist; customer-specific volumes, facilities, agreements and operating evidence do not yet apply

Assessment recommendation: this final product DPIA approves no customer processing by itself. Complete the Annex A deployment decision, document deployment-specific legal grounds and transfers, verify applicable safeguards, and obtain the controller's decision before processing patient data. For processing already underway, promptly assess

exposure, introduce appropriate interim restrictions, and preserve necessary care continuity. Follow the statutory DPIA submission and prior-consultation requirements in Section 7; this report cannot retroactively satisfy a pre-processing requirement.

1.4 2. Scope, context and DPIA screening

1.4.1 2.1 Assessment boundaries

The scope follows personal data throughout collection, use, disclosure, storage, replication, archival and disposal. It covers:

- Patient-facing registration, check-in, appointments, queues and communications.
- Clinical care, sensitive clinics, allied health, maternity/child health, immunization, emergency care, blood services and other enabled specialist services.
- Laboratories, analyzers, imaging/PACS, clinical documents and interoperability interfaces.
- Billing, SHA/DHA HIE, private insurance, payment providers, procurement and supplier contacts.
- Staff identity, access management, attendance/rosters, professional credentials, administrative and support access.
- TibaBot/AI, rules-based decision support, analytics, regulatory reporting and secondary-use proposals.
- Web/cloud, desktop sidecar, mobile and facility-hub environments; APIs, WebSockets, queues, caches, local databases, backups and observability.
- Onboarding, licensing, maintenance, development/test data, export, rights handling, incidents and exit arrangements.

Standalone TibaBot consumer services, CCTV, payroll, standalone biometric attendance, genetic sequencing and research recruitment outside the HMIS are not assumed to be active. If connected or supplied with HMIS data, record them as additional processing and reassess before activation. Commercial product information without identifiable individuals is outside personal-data processing; identifiable business contacts are in scope.

1.4.2 2.2 Current particulars and future deployment annex

Required fact	Deployment record
Assessment entity and DPO	Nexora Consulting Ltd.; **Thande W Murito**. Nexora registration/con
Customer healthcare controllers and facilities	**N/A — no customers.** Record legal entity, care level, sites and appli
Customer patient volumes and encounter rates	**N/A — no customer deployment.** Set expected and actual volume
Customer children and vulnerable populations	**N/A — no customer population.** Safeguards are assessed prospecti
Customer staff, privileged users and support contacts	**N/A for customer staff.** Nexora's own access inventory and reviewer
Customer endpoints and hubs	**N/A — no deployed customer fleet.** Web offline access is bounded
Modules and interfaces	Implemented capabilities are described in Section 5; enabled customer c
Customer file volumes and growth	**N/A — no customer records.** Populate before capacity/retention a
Processing locations	Customer-specific locations are **N/A**; actual Nexora development/certif
Customer processing start date/version	**N/A — no customers.** Record the released version and start date be
Customer incidents and complaints	**N/A — no customer operating history.** Nexora security/incident

1.4.3 2.3 High-risk screening

Indicator	Present or anticipated?	Rationale
Sensitive personal data	Yes	Health, family, reproductive, financial/property-related
Vulnerable subjects	Yes	Children, critically ill people, persons with disabilities, s
Large-scale or systematic processing	Potentially; quantify	Multi-facility, longitudinal records and routine monitori
Matching across sources	Yes	MRN, national identifiers, payer records, referrals, labor
Profiling or significant decisions	Yes, where enabled	ICU risk, condition prediction, clinical suggestions and
New technology or distributed processing	Yes	AI, offline replicas, browser SQLite, device clients and r
International processing	Documented architecture	EU Central services and potentially overseas support/su
Consequences of failure	Severe	Loss of confidentiality, discrimination, denial/delay of ca

The screening describes **envisaged healthcare use**, not an existing customer population. The assessment combines source review and specified automated regression tests; it is not a penetration test, legal approval, clinical safety certification or production audit. Non-applicable customer facts are distinguished from outstanding product-level decisions and verification.

1.5 3. Accountability and responsibilities

1.5.1 3.1 Roles in processing

Party	Expected role
Healthcare organization operating facilities	Controller for care and facility administra
Nexora Consulting Ltd.	Processor when hosting, supporting or ot
Nexora for its own business contacts, licensing administration and security purposes	Potential separate controller
Vitora HMIS	Software product, not a legal entity
Hosting, storage, sync, communications and AI suppliers	Processor/subprocessor where acting und
SHA, DHA, Ministry of Health, private insurers, receiving care providers	Usually receiving controllers for their ow
Facility staff and authorized Nexora personnel	Persons acting under their respective org
Jointly determining organizations	Possible joint controllers

Installing a standalone software package without Nexora receiving or accessing personal data does not, by itself, establish that Nexora processes that facility's patient data. Support access, license telemetry, synchronization and backups must each be assessed on their actual facts.

1.5.2 3.2 Operational accountability

Named product DPO: Thande W Murito. This identifies the privacy lead; it does not imply a signed approval, a published contact address or designation by a future customer controller. Customer-specific role assignments take place during onboarding.

Role	Accountable activities
Controller executive/sponsor	Resources, lawful operation, risk decisions and remediation deadlines
DPO/privacy lead	Independent advice, legal-basis register, consultations, rights, breach assessment and regulato
Clinical governance lead	Clinical necessity, minimum datasets, sensitive access, AI oversight, accuracy and safe downt
Security lead	Threat assessment, authentication/authorization assurance, incident command and vulnerabi
Engineering lead	Privacy-by-design, tenant isolation, data lifecycle implementation and regression evidence
Operations lead	Hosting regions, encrypted backups, endpoint/hub management, recovery and monitoring
Integration/procurement owners	Supplier contracts, recipient registers, interface payloads and transfer evidence
Records manager	Retention, legal holds, corrections, disclosures and secure destruction
HR/facility administrator	Staff access lifecycle, rosters, training and local physical safeguards

Name individuals and deputies before approval. The DPO advises and monitors; the accountable controller accepts lawful residual risk. A contractual assignment does not remove a party's statutory obligations.

1.6 4. Data subjects and information categories

1.6.1 4.1 People affected

- Patients, including walk-in patients, donors, children, pregnant people and persons receiving highly sensitive services.
- Parents, guardians, dependants, next of kin, emergency contacts and family members mentioned in records.
- Clinicians, nurses, pharmacists, laboratory personnel, administrators, contractors and other system users.
- Referring professionals, supplier representatives, payer contacts, organizational subscribers and support contacts.
- Individuals indirectly described in clinical narratives, safeguarding reports, correspondence or uploaded files.

Staff names, professional identifiers, IP addresses and attendance records are personal data even where not encrypted. Being a professional or employee does not remove data-subject rights.

1.6.2 4.2 Data classification

Category	Examples
Identity and demographics	Names, MRN, DOB, sex/gender, national ID/passport, citizenship, location, disability ind
Contact and relationships	Phone, email, address, next-of-kin details, guardian/dependant links
Health and care	Presenting complaints, diagnosis, vitals, allergies, medication, care plans, referrals, nursing
Especially sensitive context	HIV/TB, mental health, GBV, sexual/reproductive health, child protection and social-wor
Diagnostic materials	Specimen identifiers, results, blood grouping, DICOM headers/pixels, waveforms, images,
Biometric/authentication evidence	External biometric authorization references, consent/OTP status, any captured biometric
Financial and insurance	SHA/member/policy identifiers, eligibility and vulnerability status, claims, invoices, payme
Staff and access	Username, professional registration, role, facility/department, shifts, restrictions, clock-in
Security and operations	IP/device identifiers, audit entries, logs, access reasons, support tickets, license installation
AI and derived information	Prompts, chat, predictions, risk scores, generated documents, embeddings if used, reviewer

Classification rules: an MRN or UUID is linkable personal data, not anonymous information. Encryption and pseudonymization do not remove the data from scope. A boolean sensitive flag can itself reveal sensitive context, and the underlying clinical details remain sensitive. A report is anonymous only after an assessment shows individuals cannot reasonably be re-identified, including by linkage or small-group inference.

\newpage

1.7 5. Processing activity register

The register covers the identified functional and operational activities. All rows require deployment confirmation. Basis profiles **B1**–**B8** are defined in Section 7 and retention classes **T1**–**T12** in Section 11. The final controller record must select the applicable lawful ground for each distinct purpose; a profile is not a blanket authorization.

ID	Activity and purpose	Data, sources and subjects
P01	Registration, search, matching and demographic updates	Patient/guardian identity, contact,
P02	Appointments, check-in, clinic enrolment and queue management	Patient identity, clinic/time/room/s
P03	Encounters, triage, diagnosis, allergies and treatment	Patient reports, clinician observatio
P04	HIV/TB, mental health, GBV, social work, counselling and other sensitive clinics	Highly sensitive notes, family/social
P05	Inpatient, ICU/HDU/NBU, emergency, theatre, procedures and dialysis	Admissions, monitoring, nursing, m
P06	Maternity, child health and immunization	Pregnancy, delivery, mother–child li
P07	Blood donation, cross-matching and blood issue	Donor identity, screening, blood gro
P08	Laboratory orders, specimens, analyzer interfaces and results	Specimen labels, patient/order IDs,
P09	Imaging, PACS/DICOM and diagnostic document storage	Patient identifiers, images, headers,
P10	Prescribing, dispensing and walk-in pharmacy	Medication, identity/contact, allerg
P11	Referrals, transfers, shared health record, FHIR/HL7 and registry exchanges	Clinical summaries, attachments, id
P12	SHA/DHA eligibility, consent, visits, preauthorization, claims and remittances	Member identifiers, OTP/biometric
P13	Private insurance and HealthCloud/Slade360-enabled exchanges	Policy/dependant records, visit cons
P14	Invoices, receipts, refunds, accounting and M-Pesa payments	Patient/customer identity, transacti
P15	Procurement, stock, suppliers and accountable stock movement	Supplier contacts, staff actions; pati
P16	Public health, MOH/KHIS/DHIS2, IDSR/IHR and statutory case reporting	Aggregate indicators; identifiable ca
P17	Quality improvement, BI and operational dashboards	Encounter outcomes, demographics,
P18	Rules-based CDS, TibaBot clinical chat, prediction and generated documents	Clinical inputs, prompts, outputs, r
P19	Patient/staff messaging, reminders, alerts, comments and mentions	Contact addresses, message content
P20	Staff recruitment into system, invitations, onboarding, roles, roster and attendance	Staff/professional identity, role, wor
P21	Authentication, MFA, session management and emergency access	Credentials, OTP/TOTP evidence,
P22	Security logging, domain events, WebSockets, monitoring and investigations	User/resource identifiers, changes, I
P23	Offline operation, PowerSync, hub/cloud synchronization and conflict handling	Selected patient, clinical, billing and
P24	Backup, disaster recovery, migration and historical imports	Database/files/configuration, archiv
P25	Support, troubleshooting, maintenance, testing and release operations	Staff contact, redacted diagnostics;
P26	Organizational signup, subscriptions, hub licensing and update checks	Administrator/business contacts, in
P27	Clinical exports, printing, medical certificates and patient copies	Requested records, summaries, certi

ID	Activity and purpose	Data, sources and subjects
P28	Rights requests, consent changes, complaints, retention and deletion	Requester identity, authorization, re
P29	Research, model training, external benchmarking or direct marketing proposals	Proposed research/marketing datas

Scope reconciliation: compare this register with the enabled-module list, outbound network destinations, database/object-store inventory, scheduled tasks and supplier invoices. Record unmapped activities before approving the deployment; a module name alone may conceal several different processing purposes.

1.8 6. Data lifecycle, architecture and trust boundaries

1.8.1 6.1 Main data flows

```
Patients / guardians / staff / authorized external sources
                          |
          registration, care, imports, devices
                          v
 Web browser / Tauri desktop / React Native mobile
       | local state, files, caches and offline database
       |                           |
       v                           v
 Cloud Django API <--------> Facility hub on local network
       |                       | local SQLite + sync queues
       v                       |
 PostgreSQL + protected files <-+ authorized cloud/hub sync
       |
       +--> PowerSync replication --> authorized browser SQLite
       +--> tasks / events / WebSockets --> authorized subscribers
       +--> clinical / payer / payment / public-health recipients
       +--> TibaBot --> approved downstream AI services, if configured
       +--> transactional messaging providers --> intended recipients
       +--> audit / monitoring / backups / approved support
                          |
              retention, rights, export and disposal
```

This is a logical flow, not a guarantee that each connection exists in a particular deployment. The browser PowerSync route and the hub/cloud synchronization route are distinct and need separate authorization, deletion and transfer checks.

1.8.2 6.2 Trust boundaries and required checks

Boundary	Main risk	Required treatm
Patient/guardian to staff, kiosk or import	Excess collection, impersonation, inaccurate identity	Notice, minimum
User/device to API	Credential theft, unauthorized record access	Transport protec
One organization/facility/role to another	Cross-tenant or excessive intra-organization disclosure	Tenant scope plu
Cloud database to sync service to endpoint	Over-replication and bypass of API controls	Enforce equivale
Facility LAN to hub	Interception, rogue discovery endpoint, exposed admin/service	Authenticated en
Desktop WebView to local sidecar/OS	Local process access, cached data, unsafe IPC	Loopback-only se
API/tasks to external recipient	Misdirection, unlawful transfer, excessive payload	Destination allow
Event/log/object store to consumer	Subscription leakage, public files, log disclosure	Server-side autho
Production to support/test/export	Uncontrolled new copies	Synthetic data b
Live system to backup and restored system	Persistent deleted data, ransomware, key loss	Encrypted separa

1.8.3 6.3 Lifecycle requirements

1. **Collect:** identify the subject and source, deliver the appropriate notice, record the purpose and basis, and capture only necessary fields.

2. **Use and update:** apply minimum access, verify clinical identity, record provenance, correct errors with an attributable clinical amendment rather than silently rewriting history.
3. **Share:** confirm recipient, purpose, authority, approved destination and minimum dataset; record material disclosures and applicable consent evidence.
4. **Replicate:** transmit only authorized subsets; track device/facility and sync state. Treat queued writes, conflicts and tombstones as personal data.
5. **Retain:** apply class-specific schedules, reviews and restricted legal holds across databases, objects, logs, caches and suppliers.
6. **Dispose:** erase or effectively anonymize data when required, revoke links/access, expire backup copies and verify disposal. Soft deletion is not erasure.

1.9 7. Legal basis and regulatory assessment

1.9.1 7.1 Applicable framework

The primary framework is the Constitution of Kenya, Article 31; the Data Protection Act, 2019; and the Data Protection (General), Registration, and Complaints Handling and Enforcement Regulations, 2021. Assess healthcare confidentiality, the Health Act, Digital Health Act, applicable SHA/public-health requirements and professional obligations for each deployment. Record the exact instrument and provision relied on for any claimed mandatory disclosure or retention period.

The Data Protection Act and General Regulations published by Kenya Law were consulted for this revision; links are in Section 20. Industry protocols such as FHIR or DICOM and participation in a government integration are not, by themselves, lawful grounds or proof of compliance.

1.9.2 7.2 Purpose-specific basis profiles

General Regulations regulation 5 requires a demonstrable basis established before processing, with one basis at a time for the relevant processing without consent. Different purposes can have different bases. The following profiles identify decisions the controller must resolve; do not record all alternatives as simultaneous grounds.

Profile	Purpose and basis decision
B1 — Direct healthcare	Select the applicable section 30 basis for the specific service, such as nece
B2 — Emergency care	Section 30(1)(b)(iii), vital interests, where factually necessary; consider s
B3 — Legal/public duties	Select a specific legal obligation or public-interest/official-authority basis
B4 — Billing, payment and insurance	Separate service/payment contract administration from statutory reporti
B5 — Employment, security and internal operations	Separate employment/administrative contract obligations, legal duties ar
B6 — Optional consent-based purpose	Sections 30(1)(a) and 32, where consent is freely given, specific, informed
B7 — Nexora business administration	Select contract necessity or another justified basis for organization contac
B8 — Secondary use	Separate assessment for research, training, commercial use or marketing;

Consent to clinical treatment, the lawful basis for processing health data, a payer OTP/biometric authorization and consent to an optional AI/marketing purpose are separate matters. A registration checkbox does not establish all four. Sensitive-data processing must meet the relevant additional conditions in sections 44–46; section 46 does not remove the need for a section 30 basis.

1.9.3 7.3 Compliance and evidence matrix

Provision	Requirement relevant to this DPIA
Act sections 18–23; Registration Regulations	Registration and oversight
Act section 24	DPO designation, role and published contacts
Act section 25	Fairness, transparency, purpose limitation, minimization, accura
Act sections 26–29	Rights, representatives, collection and notice
Act section 30; General Regulations regulation 5	Lawful processing
Act section 31(1)–(2)	Prior DPIA for high-risk processing and prescribed content
Act section 31(3), (5)	Prior consultation where DPIA indicates high risk; submit DPIA

Provision	Requirement relevant to this DPIA
Act section 32; General Regulations regulation 4	Valid consent and withdrawal
Act sections 27, 33; General Regulations regulation 13	Representatives, children and best interests
Act sections 34–40; General Regulations regulations 7–12, 19	Restriction, objection, automated decisions, portability, retentio
Act sections 41–42; General Regulations regulations 24–25	Privacy by design/default, security and processor contracts
Act section 43; General Regulations regulations 37–38	Breach notification and communication
Act sections 44–46	Sensitive and health information
Act sections 48–49; General Regulations Part VII	Transfers outside Kenya
Act section 50; General Regulations regulation 26	Kenyan processing/serving-copy requirement for specified purpo

No universal seven-year adult or twenty-five-year child retention rule is established by the Data Protection Act. Record justified periods from the applicable healthcare/records requirements rather than repeating unverified figures from the previous version.

1.10 8. Necessity and proportionality

Processing choice	Necessity and less intrusive approach
Identifiable longitudinal clinical record	Needed to treat the correct person and maintain continuity; disconnected anonymous r
National ID/passport/phone	May support matching, contact or payer requirements; MRN and verified demographic
Organization-wide patient visibility	Can support cross-facility continuity; facility/episode-based access is less intrusive
Broad offline replication	Supports unreliable connectivity but multiplies exposure; selected patients, clinics or t
Highly sensitive notes	Necessary for specific treatment/safeguarding; detailed disclosure to general users is us
Public queues and certificates	Queue token or minimal fitness/attendance statement normally achieves the purpose
Biometrics in payer verification	Potential fraud prevention, but OTP or assisted identity verification may be less intrus
AI-assisted clinical work	May assist summarization/coding and clinical review; rules or manual review may achi
Management/public health reporting	Most trends need totals rather than individual records
Staff attendance and audit monitoring	Needed for accountable care and scheduling; continuous location/device surveillance is
Support and testing	Most defects can be reproduced using synthetic data
Long retention and backups	Supports care, legal evidence and resilience; indefinite retention increases harm

Alternatives and trade-offs must be recorded by the controller and clinical lead. Offline operation improves availability but increases confidentiality and revocation risks. Encryption reduces disclosure impact but cannot prevent excessive access by an authorized application. A favorable business case does not override an individual's statutory rights.

1.11 9. Transparency, consent and vulnerable people

1.11.1 9.1 Notice and choice

Provide a concise patient notice at collection, with a fuller accessible version. Offer English/Kiswahili and locally appropriate explanation, readable print, assisted oral explanation and accessible formats. Include:

- Controller identity and contact; Nexora's applicable role; DPO/privacy contact.
- Purposes, information categories, legal grounds, required/optional fields and consequences of not providing them.
- Recipient categories, material named integrations, cloud/offline storage and overseas transfers/safeguards.
- Retention periods or criteria; rights, how to exercise them and how to complain to the ODPC.
- AI/profiling use and meaningful explanation of significant consequences where applicable.
- Separate choices for genuinely optional processing and a straightforward withdrawal method.

Give staff and business contacts notices tailored to their own processing. For indirect collection, apply General Regulations regulation 6(3)'s fourteen-day information requirement, with the DPO documenting any applicable legal exception rather than silently omitting notice. Do not make web access the only way to obtain a notice or exercise rights.

1.11.2 9.2 Consent evidence

The evidence record should capture subject/representative, representative authority, distinct purpose, data categories, recipients/transfers where relevant, notice version, language/method, timestamp, collecting staff/system, expiration if applicable, and withdrawal history. A boolean and timestamp alone do not prove all these elements.

On withdrawal, identify the affected consent-based purpose, stop future processing/disclosures for that purpose, update queued work and downstream instructions, and explain any separate lawful retention. Do not relabel the same processing under a new basis merely to defeat withdrawal. OTP or biometric success establishes a particular verification event, not unlimited future consent.

1.11.3 9.3 Children, incapacity and safeguarding

- Apply section 33 parent/guardian consent, age-verification and best-interests requirements; verify authority proportionately and protect adolescents' confidentiality under applicable healthcare law.
- Consider the section 33(4) exception for a provider exclusively offering counselling or child-protection services; do not extend it indiscriminately to every service.
- Do not assume a disability eliminates decision-making capacity or that a relative automatically represents the person. Document any lawful guardianship/authorization.
- Record emergency necessity when consent cannot be obtained; review and provide information when appropriate after stabilization.
- For GBV, safeguarding and sensitive clinics, verify safe contact methods and whether a guardian/partner disclosure could cause harm. Avoid revealing clinic labels in reminders or public displays.
- Explain AI and external disclosures in understandable terms; do not condition essential care on unrelated optional processing.
- Use narrowly scoped, time-limited emergency access with attributable justification and independent retrospective review; emergency access is not a general cross-tenant bypass.

\newpage

1.12 10. Recipients, processors and international transfers

1.12.1 10.1 Initial recipient and transfer inventory

These entries distinguish source-evidenced architecture from deployment facts that cannot be established without an active controller, supplier contract, and runtime inventory. Each active entry must have its legal entity, role, country, processing region, backup location, remote-support locations, onward subprocessors, and contract reference recorded in Annex A before use with patient data.

ID	Recipient/service	Data and purpose
X01	Microsoft Azure hosting and any configured key services	API runtime, requests, operational data; keys if e
X02	Neon PostgreSQL	Primary cloud records and replication source
X03	PowerSync Cloud	Selected records, user/tenant claims and synchron
X04	Vercel web delivery/runtime if used	Connection metadata; personal payloads where se
X05	SHA/DHA HIE, registries and public-health bodies	Identity, eligibility, care, claims and statutory rep
X06	Private insurers, HealthCloud/Slade360 and intermediaries	Member/visit authorization, claims and remittanc
X07	M-Pesa and other configured payment services	Payment reference, amount and necessary contact
X08	TibaBot and downstream model/inference providers	Clinical prompts, session/identity metadata, outp
X09	Resend, facility SMTP and configured SMS/push services	Recipient addresses, messages and delivery metad
X10	Object storage, PACS, external laboratories and backup providers	Diagnostic files, attachments, images, backups an
X11	Support, observability, CI/CD and ticketing suppliers	Redacted logs, device/account metadata; exceptio
X12	Receiving facilities, patients/representatives and authorized auditors	Purpose-limited summaries, copies or evidence

1.12.2 10.2 Contract requirements

Written controller–processor and authorized subprocessor arrangements must specify subject matter, duration, instructions, purposes, data types, subjects, confidentiality, security, incident reporting, rights assistance, DPIA assistance, audit/inspection, return/deletion and termination. Obtain prior controller authorization for subprocessors

and equivalent downstream obligations. Address government access requests, support access, storage/backup regions and notification of material supplier changes.

Routine controller-to-controller sharing also needs an appropriate agreement and lawful authority. Government status, vendor security certifications or a contract alone do not establish the lawfulness of a particular disclosure.

1.12.3 10.3 Transfer assessment and localization

Before an overseas flow, record:

1. Exporter/importer identity, roles, purpose, countries, data categories, subjects, frequency, volume and onward recipients, including remote support and backups.
2. The applicable transfer ground under section 48 and General Regulations Part VII; for sensitive data, section 49(1)'s consent and appropriate-safeguards requirements and any specifically applicable legal provisions.
3. Destination protections, enforceable rights, recipient practices, government-access exposure, redress and contractual/technical safeguards. EU hosting is not automatically a Kenyan adequacy determination.
4. Encryption in transit/at rest, actual key access, pseudonymization where possible, restricted recipient access and monitoring. Encryption does not make an overseas transfer disappear.
5. Evidence of compliance with regulation 26 for primary/secondary healthcare: qualifying Kenyan processing or at least one serving copy in a Kenyan data centre. Confirm the actual copy is usable, maintained, secure and covers the relevant records.
6. Informed notice/consent where required, controller/DPO decision, unresolved risks, review date, and regulator submissions/consultation where required.

Record actual locations rather than relying on a supplier's headquarters. An on-premise hub's suitability as a qualifying arrangement requires assessment; browser SQLite, an occasional backup or an unverified local device is not assumed sufficient. Where requirements cannot be met, redesign or restrict the affected overseas flow and maintain a lawful clinical continuity arrangement.

1.13 11. Retention, deletion and decommissioning

1.13.1 11.1 Retention schedule for controller adoption

Periods marked **proposed** are policy recommendations, not verified configuration or statutory periods. Periods marked **pending** must be set before approval. Each final schedule entry must include exact duration, legal/purpose justification, trigger, owner, storage locations, hold rules and disposal method.

Class	Records and retention purpose	Period/trigger
T1	Clinical record, diagnostic files, consent relevant to care, signed documents and referrals	**Pending:** set
T2	Invoices, payments, claims, preauthorizations, procurement and financial evidence	**Pending:** rec
T3	Staff, organization contacts, rosters, supplier/licensing administration	**Pending:** emp
T4	Audit, security accountability and emergency-access reviews	**Documented**
T5	Offline records, local caches, queued writes and conflicts	**Implemented**
T6	Database/media backups and recovery logs	**Source defau**
T7	Routine application logs, event delivery, integration troubleshooting, temporary import/migration files	**Proposed:** 30
T8	OTPs, access/refresh tokens, biometric authorization references and delivery/consent evidence	**Source defau**
T9	Analytical extracts, public-health/quality reports	Identifiable sou
T10	AI prompts, chats, outputs, caches and provider logs	Clinician-adop
T11	Download links, exports, printed copies and support bundles	**Proposed:** do
T12	Rights requests, complaints, DPIA decisions and breach records	**Pending:** evi

1.13.2 11.2 Deletion, restriction and legal holds

- Maintain a deletion/restriction manifest linking the affected record and purpose to primary storage, related records, attachments, analytics, AI history, replicas and recipients. Use minimum identifying data in the manifest.
- A legal hold must state authority, scope, owner, start date and review/release criteria. Apply restricted access; it is not permission for unrelated reuse or indefinite retention of everything.

- Apply lawful corrections/erasure to downstream processors and reasonable notification to other recipients. Record unsuccessful attempts and escalate.
- Backups should expire on a controlled schedule and remain isolated from normal use. When immediate selective deletion is impracticable, document the limit, prevent active use and reapply deletion/restriction instructions on restore before reconnecting.
- Disconnected devices cannot be assumed remotely wiped. Use managed encryption and enforceable offline expiry, track reconnect cleanup, and assess irretrievable devices as potential incidents.
- Crypto-erasure is valid only where all relevant keys/copies are addressed; deleting a shared key could destroy unrelated records and is not a substitute for a record-level plan.

1.13.3 11.3 Exit and decommissioning

At facility closure, contract termination or device retirement: agree the lawful transfer/retention plan; export records securely; verify recipient acceptance and clinical continuity; revoke users, tokens, integrations and device certificates; remove local databases/caches/files and provider copies; expire backups under contract; sanitize or destroy media; and issue a disposal record. Software uninstallation alone does not prove erasure.

1.14 12. Control assessment and assurance

1.14.1 12.1 Evidence labels

- **O — Observed in source/configuration:** reviewed in the current repository; production effectiveness is not implied.
- **T — Regression-tested:** the specified behavior passed automated tests with synthetic data/mocked external services; scope and commands are recorded below.
- **U — Supplied by Nexora:** an organizational fact provided for this assessment; not a code-derived fact or a signed approval.
- **D — Documented:** described in an implementation guide or project instructions, operational effectiveness not verified.
- **V — Deployment verification required:** fact or control not established by this review.
- **R — Required/proposed:** treatment to implement or evidence before taking risk-reduction credit.

No control below is classified as production-tested by this assessment. Evidence references **E01**–**E21** are listed in Section 20. Customer deployment verification is N/A until onboarding; product/certification environment verification remains applicable. Historical documentation does not override current source or test results.

1.14.2 12.2 Technical and organizational control matrix

ID	Control and present evidence
C01	Source defines 30-minute access/one-day refresh tokens and dashboard logout after 30 idle minutes. Cookie refresh now u
C02	`TenantScopedViewMixin` and patient queryset implement tenant scope, sensitive-record filtering and permission-checked
C03	Patient/emergency-contact encryption properties and KMS-backed helpers present (E04,E05); KMS providers described (
C04	Signed per-model read and sensitive-access claims, tenant filters and inherited patient scope now gate clinical replication;
C05	Web PowerSync uses server-verified user/facility-specific databases, a fresh-sync read gate and credential expiry. Logout
C06	Transport and deployment protections described (E01,E10)
C07	Source includes hash-chain verification and a task that creates critical notifications on a mismatch (E18)
C08	Emergency-access models record reason, scope, access mode, expiry and reviewer; source checks active/unexpired grants (
C09	Public queue view uses unauthenticated access and a minimized serializer; clinic name is returned (E12)
C10	JSON, SSE and ECG report requests apply recursive direct-identifier removal and text redaction; known structured nam
C11	DHA and private-insurance workflows documented (E01,E11)
C12	Backup script fails before dumping when the encryption key is missing, uses restrictive file permissions and streams datal
C13	Validation, natural-key hub remapping and conflict management described (E01,E10)
C14	Source selects facility SMTP when its required facility/configuration flags permit it; otherwise it selects Resend when con
C15	API PII redaction helper exists (E05); audit/events and monitoring documented (E07,E16)
C16	Secure development, vulnerability and deployment practices described (E01)
C17	Rights APIs and privacy policies described in prior material
C18	Nexora identifies **Thande W Murito** as DPO; there are no customers

1.14.3 12.3 Code findings, completed treatment and remaining limits

1. **Authentication:** the cookie-refresh path previously issued only an access token. It now uses the standard refresh serializer, rotates the refresh cookie when configured, blacklists the previous refresh token and rejects disabled users. Access-token expiry is not the same as immediate access-token revocation.
2. **Replication:** the prior API-only sensitive filter and obsolete columns were corrected in source. Tests execute every stream query against schemas built from current Django models and check sensitive/foreign-tenant exclusion through the clinical hierarchy. Signed per-model permissions and policy version are required. PowerSync compiler 0.43.0 accepts the full configuration without warnings after eliminating unsupported YAML aliases/chained CTE references. Actual service deployment/replication remains an acceptance step.
3. **Global templates:** only active system templates are selected; creator identifiers are no longer exported. Content review is still required before a template is designated system-wide.
4. **Offline lifecycle:** new sessions cannot adopt the previous user's database; credentials must match the server-returned user/facility, and local reads wait for a fresh sync. A fresh offline session requires connectivity for authorization; an already authorized session may continue only within credential validity. Unsent work is retained in closed owner-specific storage, not silently erased. This does not secure the files against an OS-level attacker or guarantee immediate revocation of a disconnected device.
5. **Backups:** missing encryption credentials now stop the backup. Plaintext database/media intermediate files are not persisted by the updated backup path. The round-trip test uses synthetic dump output and real GPG; it does not establish operational recovery of a live database.
6. **AI:** recursive scrubbing now covers transport paths rather than only selected top-level message fields. Direct identifiers found in structured payloads are removed and scrubbed from nested text. Pattern/known-value redaction cannot recognize every identifying narrative or de-identify binary images/documents; these remain personal-data processing where identification is possible.
7. **Historical material:** earlier approval, encryption, hosting and retention assertions are not accepted as implementation evidence. This revision uses current code and specified tests; customer deployment facts remain N/A and infrastructure facts require operational evidence.

\newpage

1.15 13. Risk assessment methodology

Risk is assessed as harm to people, including confidentiality, integrity, availability, autonomy, dignity and fair access to care. Commercial or regulatory impact on the organization is secondary to this assessment.

1.15.1 13.1 Scoring

Score	Likelihood over an indicative 12-month operating period	Impact on an affected individual
1	Rare: exceptional circumstances with strong verified barriers	Negligible inconvenience, readily reversible
2	Unlikely: plausible but not expected in normal operation	Limited distress or disruption, reversible with
3	Possible: credible failure path under expected operating conditions	Material distress, financial loss, discriminatio
4	Likely: broad exposure or important controls absent/uncertain	Serious harm, sustained exclusion, substantia
5	Almost certain: recurring/ongoing failure expected without intervention	Severe/irreversible harm, threat to life/safety

Score = likelihood × impact. Low: 1–4; Moderate: 5–9; High: 10–16; Critical: 17–25. The scale is a prioritization tool, not a statistical prediction. One person's severe harm matters even when the affected population is small; broad scale can increase likelihood/exposure and urgency.

- **Inherent:** before safeguards.
- **Current provisional residual:** a conservative forecast for an envisaged deployment, not measured exposure of current customers (there are none). Code/test evidence is credited only within its demonstrated scope; operational effectiveness and remaining safeguards require acceptance.
- **Target residual:** expected only after specified treatment and evidence acceptance. It is not today's risk.

Do not average away high risks across activities. Low/moderate residual risks still require recorded controller acceptance. High/critical current risks require priority treatment, a specific decision on restrictions and the section 31 consultation analysis. No score permits unlawful processing. Re-score at deployment using actual volumes, incidents, control evidence and stakeholder feedback.

1.16 14. Detailed risk register

Scores are shown as **likelihood × impact = total**. Owner roles must be assigned to named people in Section 15. Every row is **open** until evidence and a decision are recorded.

Risk	Activities and harmful scenario
R01	P01–P28: cross-tenant or excessive cross-facility access reveals another person's care
R02	P04,P18,P23: sensitive patient records reach unauthorized offline clients or AI context, causing stigma or violence
R03	P01,P04,P23: legacy contact fields or non-global templates are replicated unnecessarily or sync fails
R04	P21–P26: stolen credentials, weak recovery or excessive admin access exposes or alters records
R05	P01–P28: insider browsing or abusive emergency access exposes sensitive/family information
R06	P23–P25: lost/shared device, retained session or unencrypted local data reveals health history
R07	P20–P23,P28: revoked user/consent retains offline access or queued disclosure after entitlement changes
R08	P03,P08,P11,P23,P24: wrong-patient merge, FK mapping or stale conflict overwrites clinical information
R09	P01–P24: network interception, rogue hub or exposed local service discloses credentials/records
R10	P01,P12,P14,P24: exposed encryption/signing keys or incomplete backfill allows identity fraud
R11	P03,P08,P23,P24: ransomware, unavailable backup or lost keys prevents timely care
R12	P12,P18,P22,P25: logs, events, exceptions or support bundles expose clinical data or secrets
R13	P21,P22,P27: audit rewriting, missing events or misuse of signing keys hides abuse or falsifies authorship
R14	P09,P11,P12,P27: publicly accessible files, malicious uploads or embedded DICOM identifiers disclose records
R15	P02,P19,P27: queue display, wrong SMS/email, printout or certificate reveals attendance/diagnosis
R16	P01–P29: unclear grounds, bundled consent or covert secondary use deprives individuals of control
R17	P01,P04–P07,P18,P28: invalid guardian access or coercive disclosure harms a child or vulnerable person
R18	P11–P13,P18,P23–P25: overseas processing lacks sufficient safeguards/consent or qualifying Kenyan serving copy
R19	P11–P19,P24–P26: supplier misuse, hidden subprocessors or unapproved failover causes uncontrolled disclosure
R20	P12–P14: replayed callbacks, bad recipient mapping or excessive claim payload leads to fraud/denial of care
R21	P12,P13,P21: biometric/OTP capture, reuse or inaccessible verification exposes immutable identifiers or excludes patient
R22	P18: AI prompts, retrieval or provider training discloses identifiable clinical data across sessions/tenants
R23	P03,P05,P12,P18: inaccurate or biased automated output influences treatment, discharge or eligibility without meaningf
R24	P16,P17,P29: small cells, linkage, quasi-identifiers or pseudonymous datasets re-identify patients
R25	P20–P22,P26: excessive staff monitoring or exposure of work restrictions causes discrimination
R26	P23–P29: excessive retention or ineffective erasure leaves records recoverable in backups, AI history or devices
R27	P27,P28: incomplete export, incorrect representative or missed rights deadline denies rights or leaks another person's da
R28	P21–P25: delayed detection/notification prevents protective action and prolongs exposure
R29	P09,P24,P25: vulnerable dependency, compromised update/CI or production data in test/AI tooling creates broad comp
R30	P23–P28: incomplete migration or vendor/device exit loses care history or leaves unauthorized copies

1.17 15. Risk treatment and implementation plan

Priority definitions: P0 = urgent exposure assessment and prerequisite for starting/expanding the affected high-risk flow; P1 = complete before controller approval of the relevant activity; P2 = continuing assurance. These are proposed governance milestones, not a statement that production has been stopped or controls have been implemented. For existing processing, the controller must immediately set dated interim measures and remediation deadlines proportionate to harm and clinical continuity.

Action	Priority / milestone	Deliverable and evidence of completion
A01	P0 — before sensitive offline replication	Reconcile actual streams, physical schema, migrations and g
A02	P0 — before access-control acceptance	Execute cross-tenant, intra-tenant role and sensitive-record r
A03	P1 — before privileged access approval	Evidence production MFA, reset/recovery, session/revocatio
A04	P0 — before unmanaged offline/LAN use	Inventory clients/hubs, enforce managed storage encryption
A05	P1 — before encryption/security assurance	Confirm TLS, key/secret inventory, encryption backfills and
A06	P0 — before unapproved disclosure/overseas processing	Complete actual purpose/basis and recipient register, contra
A07	P1 — before rights/retention approval	Approve exact schedules; demonstrate access/correction/rest
A08	P1 — before integration/sync clinical acceptance	Demonstrate patient matching, natural-key/FK mapping, du
A09	P0 — before unassessed identifiable AI processing	Trace each provider/data/region/retention path; validate ses

Action	Priority / milestone	Deliverable and evidence of completion
A10	P1 — before security approval	Review audit coverage, protected checkpoints, log/event red
A11	P1 — before external disclosure channels accepted	Review public queue/clinic labels, notifications, SMS/email
A12	P1 — before continuity/incident approval	Restore representative database/files/keys; measure actual R
A13	P1, then P2 — before sign-off and ongoing	Complete patient/staff/clinical consultation, guardian/safeg
A14	P1 — before report/secondary dataset release	Validate statutory report authority and minimal case fields;
A15	P1 — final acceptance gate	Populate deployment particulars, named owners, dates, evid

For each action, maintain: **named assignee; agreed due date; interim protection; evidence location; verifier; completion date; affected risks; revised score; acceptance decision**. Technical sub-actions completed in this revision are recorded below. Customer-specific operating evidence is N/A until deployment; product governance and supplier decisions still require completion. Passing tests close their defined engineering scope, not an entire risk or statutory obligation.

1.17.1 Engineering treatment status — 2 October 2026

Related actions	Completed implementation
Authentication (A03)	Cookie refresh rotation, old-refresh rejection, disabled-user rejection and invalid-cookie clearing tested
A01, A02	Signed model-read/sensitive claims; patient-scope inheritance; obsolete columns removed; system-only g
Offline lifecycle (A04)	Owner-specific databases; verified server identity/scope; fresh-sync read gate; bounded credential validi
A05, A12	Backup fails without a key; private file permissions and encrypted streams; synthetic dump/GPG round
A09, A10	Recursive AI text/JSON minimization, known-identifier redaction, generic upload filenames and no ech
A13, A15	Product DPO identified as Thande W Murito; pre-customer scope and N/A deployment facts recorded

1.17.2 Minimum acceptance exercises

Use synthetic people and representative deployment configuration. Capture expected/actual outcome and version without putting real patient data in reports.

1. A user in another organization, wrong facility, wrong role and without sensitive permission cannot retrieve the record through API, attachment, search, event, export or offline database.
2. A clinician's role/account/facility changes while a device is disconnected; verify the approved offline limit, reconnect rejection/cleanup and preservation of legitimate unsynced care.
3. A corrected or erased/restricted record is traced through related tables, object storage, AI history, analytical extracts, recipient notifications and restored backups.
4. A deliberately mismatched patient/import/callback cannot attach results, claims or payments to the wrong person; conflicts reach authorized human review.
5. A public queue, email, support bundle, diagnostic file and log capture contain only the approved minimum data.
6. An AI conversation cannot access another tenant/session; clinicians can reject outputs and patients can obtain review of significant automated decisions.
7. Restore representative clinical records, files, audit evidence and keys within adopted objectives; complete a timed incident and rights-request exercise.

\newpage

1.18 16. Data subject rights procedures

1.18.1 16.1 Access channels and handling workflow

Provide in-person, telephone, written and electronic request channels, with accessible support. A patient need not possess an application account. The processor forwards requests promptly to the responsible controller and assists under instructions; it does not decide substantive rights on the controller's behalf without authority.

1. Log receipt, request type, source, responsible controller and statutory deadline. Acknowledge promptly; proposed internal target is one working day.

2. Verify identity and representative authority proportionately, using existing trusted channels where possible. Avoid collecting a complete identity document unnecessarily or retaining verification copies indefinitely.
3. Locate the person's information across all modules, diagnostic files, AI history, logs where relevant, offline stores and processors. Protect third parties' rights and confidential safeguarding information.
4. Assess the requested right, applicable legal exceptions and clinical/legal retention. Separate access/erasure of personal data from amendment of an attributable clinical record.
5. Fulfil securely, issue reasoned decisions where refused or limited, explain complaint routes and notify affected recipients where required.
6. Confirm downstream action, record evidence and close the request. Escalate impending deadlines; do not assume identity checks automatically suspend statutory time.

1.18.2 16.2 Rights and deadlines

The deadlines below reflect the cited Kenyan provisions, rather than a blanket thirty-day rule. The DPO must keep them current and handle any permitted extension/refusal in accordance with the relevant provision.

Right/request	Operational response
Information/notice	Explain purposes, sources, recipients, safeguards and rights accessibly
Access	Provide confirmation, required processing information and a secure copy; assess third-pa
Rectification	Correct inaccurate/outdated/incomplete/misleading data and notify relevant recipients;
Restriction	Mark and actually limit processing, including outbound queues and replicas; allow only
Objection	Stop the relevant processing or assess/document an applicable overriding ground; explai
Portability	Supply structured, commonly used machine-readable data, or direct transfer where techn
Erasure	Assess the grounds and exceptions, respond, and implement accepted erasure across cop
Consent withdrawal	Stop the specified consent-based processing and propagate withdrawal; explain separate
Significant solely automated decision	Explain, provide meaningful human intervention and reconsideration, receive the person
Complaint	Offer controller/DPO contact and access to the ODPC complaints mechanism without r

Implementation distinctions: `is_sensitive` is an access classification, not statutory restriction of processing. Soft deletion is not erasure or anonymization. A single patient JSON/FHIR endpoint may omit files, financial records, AI results and other relevant data. Verify completeness and safe delivery instead of treating an endpoint's existence as fulfillment of a right.

1.19 17. Incident response and continuity

1.19.1 17.1 Preparedness and detection

Maintain controller/processor incident contacts, deputies, supplier escalation routes and clinical downtime procedures. Monitor suspicious access/export, failed authentication, unusual sensitive/break-glass use, unauthorized sync, audit-chain failures, public objects, integration replay, wrong-patient associations and backup failures. Local offline access may not generate a central event immediately; document detection and synchronization limitations.

1.19.2 17.2 Response steps

1. **Detect and record:** capture discovery and awareness times separately, affected systems, reporter, initial scope and safety implications. Preserve evidence under controlled access.
2. **Contain proportionately:** revoke affected sessions/credentials, isolate devices/streams/objects, suspend compromised integration paths and protect necessary care delivery. Key rotation must be planned to avoid rendering records unreadable.
3. **Assess harm:** identify individuals/categories, sensitivity, actual access, possible misuse, availability/integrity effects, vulnerable people and likelihood of discrimination or physical harm. Encryption matters only if effective for the affected data and keys were not compromised.
4. **Escalate and notify:** follow the legal duties below; supplier delay or incomplete investigation must not hide the controller's notification clock.
5. **Recover:** patch the cause, restore validated data/keys, reconcile records and offline writes, reapply deletion/restriction instructions and monitor for recurrence.

6. **Learn:** record cause, effects, decisions and remedial actions, update risks and provide targeted training/control improvements. Record the basis for any decision not to notify.

1.19.3 17.3 Notification obligations

Communication	Requirement
Processor to controller	Act section 43(3):**without delay and, where reasonably practicable, within 48 hours** of
Controller to ODPC	Section 43(1): where unauthorized access/acquisition creates real risk of harm, notify**without d**
Controller to affected people	Communicate in writing within a**reasonably practical period** where required by section 43; u
Other recipients	Notify contracting parties, insurers, health authorities or law enforcement where a specific obliga

The initial notice should include the awareness timeline, nature of breach, affected categories and estimated numbers, risks/likely harm, containment/remediation, protective advice and DPO/contact details. Provide additional information in phases without undue delay where necessary. Do not defer notice until every fact is known. Retain facts, effects, decisions and remedial action as required by section 43(8).

1.19.4 17.4 Continuity and clinical safety

The approved Disaster Recovery Plan and Backup and Recovery Policy set a **24-hour RTO** and **24-hour RPO** for Tier 1 recovery, with a 48-hour maximum tolerable period of disruption. A Tier 1 database with approved continuous transaction-log capture must meet a 15-minute operational RPO. These are targets, not measured achievements. Each facility must confirm in Annex A that these targets are safe for its services, including round-the-clock inpatient/emergency operations, and adopt stricter objectives where required.

Provide safe downtime recording, secure temporary paper handling, critical-result escalation, reconciliation ownership and identity checks on re-entry. Exercise database, file, key, audit and attachment restoration together. Offline capability supports continuity only when data is sufficiently current, authorized and safely reconciled.

1.20 18. Consultation, monitoring and review

1.20.1 18.1 Consultation register

No interviews or formal approvals were performed in this review. There are no customer patients or customer staff to consult at present; their deployment consultation is N/A until onboarding. Pre-customer clinical/patient-representative consultation can still inform product design and must not be fabricated. Record dates, participants, concerns, changes made and reasons for rejecting recommendations when consultation occurs.

Stakeholder	Questions to resolve
Patients/patient representatives, including low-literacy and rural users	Are notices understandable, choices real, chan
Parents/guardians, child/safeguarding representatives and disability advocates	Are authority, confidential care, consent and b
Clinical and sensitive-service teams	Is data collection necessary; are restrictions, e
Staff/HR representatives	Is attendance/security monitoring proportiona
DPO/legal and records management	Are bases, localization, transfers, retention an
Nexora engineering/security/operations	Do implementation and runtime controls matc
Payers, receiving providers and subprocessors	Are purpose, location, onward disclosure, secu
Controller management	Are resources, actions, accepted residual risks
ODPC	Manage statutory submission and prior consul

If consultation is limited or inappropriate, document why, the substitute evidence used and how affected people's interests were represented.

1.20.2 18.2 Monitoring schedule

These are proposed minimum governance frequencies; refine using facility scale and risk.

Review/control metric	Frequency / target
Critical privacy/security alerts and backup failures	Daily operational review; urgent escalation by severity
Break-glass invocations	Review every use promptly; proposed within 1 working
Rights requests and deadlines	Active-case monitoring each working day; no overdue st
Unmanaged devices, over-age offline access, failed sync/deletion tasks	Daily exception report and risk-based resolution
Privileged, sensitive and cross-facility access	Monthly exception review; formal role recertification qu
Audit integrity and disclosure-channel sampling	Verify scheduled jobs/alerts; monthly sample of access,
Retention and deletion effectiveness	Monthly job exception review; quarterly sample through
Restore and incident exercise	Quarterly representative restore; at least annual combin
AI quality, bias, overrides and complaints	Before model/prompt changes and at a risk-based regul
Supplier/transfer/localization assurance	At onboarding, material change and at least annually
DPIA and action closure	Monthly until open high risks resolved; at least annual

Track evidence of performance rather than merely the presence of a policy: unauthorized-disclosure incidents, restriction propagation failures, device cleanup completion, rights response times, overdue high-risk actions, backup restore success and reviewed emergency-access percentage.

1.20.3 18.3 Reassessment triggers

Reassess before a new module, data category, recipient, hosting region, integration, secondary purpose, AI model/provider, biometric flow, major scale increase or material retention/access change. Also reassess after a serious incident, significant complaint, control failure, legal/regulatory change, acquisition, facility merger, new vulnerable population or evidence of a higher likelihood/impact than recorded. Record version, scope, decision and communication to affected controllers.

\newpage

1.21 19. Decision, approval and residual-risk acceptance

1.21.1 19.1 Current assessment decision

Decision: approved as a final pre-customer product DPIA when the Section 19.2 execution record is signed. This decision approves the product assessment methodology, product-level safeguards, and the mandatory deployment gate. It does not approve a healthcare controller, facility, patient-data processing, international transfer, optional module, or supplier route. Nexora has no customers, so forecast risk scores do not describe current customer exposure. The engineering treatments in Section 15 are complete only within their stated scope; deployment, supplier, organizational, and independent-review evidence remains mandatory in Annex A.

Before approving the relevant deployment:

1. Complete deployment facts, purposes/bases, recipient locations and exact retention decisions.
2. Resolve P0 treatments and verify material safeguards with the acceptance exercises and independent review.
3. Complete stakeholder consultation, DPO advice and required ODPC submission/consultation steps; record any conditions or directions.
4. Re-score risks using actual evidence. For any remaining risk, record rationale, affected people, safeguards, restrictions, accountable owner and review/expiry date.
5. Obtain the controller's signed decision and communicate permitted scope to Nexora, facility teams and authorized processors.

Possible recorded outcomes are: **approved for the specified scope**, **approved with explicit lawful conditions and dates**, or **not approved/requires redesign**. No decision can waive a statutory requirement. For an existing deployment, separately record the immediate operating restrictions and lawful continuity arrangements while remediation proceeds.

1.21.2 19.2 Product DPIA Execution Record

Role	Name/contact	Advic
Assessment author/coordinator	Nexora DPIA author recorded in the controlled document register	Confi
Technical/security reviewer	Named Nexora technical/security reviewer in the controlled approval record	Valid
Clinical governance reviewer	Named independent clinical-governance reviewer in the controlled approval record	Valid
Records-management reviewer	Named Nexora records-management reviewer in the controlled approval record	Valid
DPO/privacy lead	**Thande W Murito**, Nexora DPO	Provi
Legal/procurement reviewer	Named Nexora legal/procurement reviewer in the controlled approval record	Valid
Nexora processor representative	Authorized Nexora operations representative named in the controlled approval record	Confi
Nexora executive approver	**Nexora Managing Director or a formally delegated executive**	Appr

An unsigned copy is the final document content but is not an executed approval record. The executed controlled copy must retain the completed names, approval references, and dates. A facility/controller executive and the facility DPO or privacy lead must separately sign Annex A before that facility processes live patient data.

1.21.3 19.3 Residual-risk acceptance record

No product residual risk is accepted by default. If Nexora accepts a product-level residual risk, it must use the following record. A facility may not rely on this record for its own deployment risk; it must complete the Annex A decision instead.

Required field	Entry
Risk ID and enabled activity/deployment	Record only a product-level risk that Nexora is authorized to
Current residual score and evidence	Record the assessed score with supporting evidence; do not c
Affected subjects and foreseeable harm	Identify the affected group and credible harm.
Why further mitigation is not proportionate, or remaining work	Record the decision, remaining work, and completion date.
Compensating safeguards and operating limits	Record enforceable safeguards and any module, supplier, geog
Legal/transfer/consultation requirements satisfied	Attach the applicable references and approval evidence.
DPO advice and controller response	Record advice and explain any disagreement.
Named accountable risk owner and accepting executive	Name the accountable Nexora owner and Managing Director
Acceptance date, expiry and reassessment trigger	Record a fixed expiry and the reassessment trigger.

No residual risks are formally accepted in this product DPIA at the time of issue.

1.21.4 19.4 Annex A: Mandatory Facility Deployment Decision

Complete this annex for each controller/facility before onboarding, enabling a high-risk module, or processing live patient data. Attach the referenced evidence to the controlled copy; do not substitute a verbal confirmation or product-level statement.

Required deployment fact or evidence
Controller legal entity, facility name, registration details, accountable executive, DPO/privacy contact, and clinical-governance l
Go-live date, Vitora release, facilities, modules, interfaces, patient/staff volumes, children/vulnerable populations, and devices/h
Purpose-specific lawful bases, sensitive-data conditions, notices, consent/representative process, and any statutory reporting aut
Active supplier/recipient inventory: legal entity, role, country, processing/backup/replication/support locations, contract/DPA,
Kenyan processing or serving-copy evidence and any international-transfer safeguards, notice/consent, regulator submission, or
Controller retention schedule: T1-T12 periods, triggers, legal authority, holds, disposal, primary/backup/offline/supplier locatio
Deployment verification: identity/RBAC/MFA, tenant isolation, endpoint encryption, backup/restore, immutable offsite storage
Consultation record: clinical, staff/HR, patient/representative, safeguarding, supplier, DPO/legal, and any ODPC consultation
Open risks, operating restrictions, action owners/dates, residual-risk assessment, and evidence references

Deployment decision role	Name	Signature or approved electronic equivalent	Date
Facility/controller executive			

Deployment decision role	Name	Signature or approved electronic equivalent	Date
Facility DPO or privacy lead			
Facility clinical-governance lead			
Facility records-management lead			
Nexora authorized processor representative			

Deployment decision: [ ] Approved for the documented scope. [ ] Approved with documented conditions and expiry. [ ] Not approved; redesign or further evidence required.

1.22 20. Evidence, legal references and version history

1.22.1 20.1 Project evidence register

Sources support only the observations described. Implementation documents may describe planned, historical or deployment-dependent behavior; production verification remains necessary. File/section references are preferred over brittle line numbers.

Evidence	Source	Use in assessment
E01	Project instructions, README, module reference	Product scope, privacy/RBAC c
E02	PowerSync integration	Browser/local read architecture,
E03	PowerSync Sync Streams	Current source: signed read/sens
E04	Patient/contact models	Observed encrypted properties fo
E05	PII helpers	Observed KMS-backed encryptio
E06	Key management	Documented local/Azure provide
E07	Audit integrity and signatures	Documented hash chain, verificat
E08	Emergency access	Documented time-limited access,
E09	TibaBot API guide	AI/chat/predictor capabilities, ic
E10	Facility hub guide	Local Django/SQLite, desktop/n
E11	HealthCloud operations	Private-payer integration, operat
E12	Clinic views: PublicQueueView	Observed public route, minimize
E13	MFA implementation and E01	Authentication assurance follow-
E14	Backup script	Required key, AES-256 streams,
E15	Email service	Actual facility SMTP, Resend an
E16	Domain events, monitoring and E01	Follow-up references for full even
E17	Cookie auth, cookie tests, backup tests	Executed regression evidence for
E18	Tenant mixin, patient views, audit verification, emergency access service, models	Source-derived authorization, exp
E19	Sync credentials, stream privacy tests	Real checked-in SQL executed ag
E20	Sync lifecycle, connector, auth storage, auth tests, cleanup tests	Mocked-SDK session-isolation, la
E21	AI sanitizer, AI transport, privacy tests	Recursive redaction and error-me

Executed verification commands (from `backend/` or `web-app/` respectively):

```
poetry run pytest tests/core/test_cookie_refresh_privacy.py tests/infrastructure/test_backup_dr.py --no-cov
poetry run pytest tests/core/test_powersync_stream_privacy.py tests/integration/test_powersync_tokens.py --
poetry run pytest tests/ai --no-cov -q
npm test -- --runInBand __tests__/lib/auth/context.test.tsx __tests__/lib/auth/storage.test.ts __tests__/ap
npx tsc --noEmit
```

These checks passed during implementation. External AI services and customer infrastructure were not called by the regression fixtures. Additionally, `SqlSyncRules.validate` from **`@powersync/service-sync-rules` 0.43.0** was run locally under Node 24 against the complete YAML and returned **no errors or warnings**. That compiler check complements the SQLite row-policy/schema tests; neither proves target deployment. The synthetic backup round trip does not substitute for a real disaster-recovery exercise.

Evidence still required: production configuration and physical schema; active streams and client caches; network/recipient inventory; provider contracts and regions; Kenyan serving-copy arrangements; migration/backfill

results; encryption/key custody; authorization and isolation tests; vulnerability findings; restore and deletion evidence; supplier AI retention/training terms; exact lawful bases/retention authorities; ODPC registration/submission records; rights/incident exercises; stakeholder feedback and signed decisions.

1.22.2 20.2 Legal and regulatory sources

- Constitution of Kenya, 2010 — Article 31 privacy foundation.
- Data Protection Act, 2019, Kenya Law — consulted for processing principles, DPIA, rights, security, breach and transfer requirements.
- Data Protection (General) Regulations, 2021, Kenya Law — consulted for consent, rights deadlines, contracts, retention, localization and transfers.
- ODPC regulatory framework — official access to the Act, General Regulations, Registration Regulations and Complaints Handling and Enforcement Regulations.
- ODPC guidelines — obtain the current applicable DPIA and health-data guidance when completing the controller assessment.

The DPO/legal reviewer must record the current applicable healthcare, reporting, confidentiality and records instruments, plus any regulatory directions specific to the deployment. A reference link is not evidence that a controller has fulfilled the requirement.

1.22.3 20.3 Version history

Version	Date	Change and status
1.0	28 December 2025	Initial Phase 0 DPIA. Historical document labeled itself approved while reviews/signatures rema
2.0	2 October 2026	Comprehensive product/deployment assessment covering clinical and operational activities, vuln
2.1	30 September 2026	Source-based privacy fixes and regression evidence; records pre-customer status and DPO Thand
3.0	15 October 2026	Final product-level DPIA. Replaces ambiguous placeholders with explicit product-scope decision

Document owner: Thande W Murito, Nexora DPO. **Next scheduled review:** 15 October 2027 or earlier on material change/customer onboarding. **Approval status:** final product DPIA; execution requires completed Section 19.2 approvals. Facility deployment is prohibited until Annex A is completed and signed.